PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Hygiène de la sécurité des SI

09-440 PSE-ER F4-9 Les 40 règles d'hygiène sécurité des SI — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'authentification forte exige deux facteurs parmi la connaissance, la possession ou l'inhérence.
2. Le réseau d'administration doit être cloisonné du réseau bureautique par un dispositif physique, des tunnels IPsec ou au minimum des VLAN.
3. Les correctifs de sécurité doivent être appliqués dans le mois suivant leur publication.

Synthèse de la sensibilisation et formation

Notion	À retenir
Former et sensibiliser	Équipes : formation à la **prise de poste** puis régulière. Utilisateurs : enjeux, règles, pas d'**équipements personnels**, mots de passe secrets, **verrouillage** systématique.
Maîtriser l'infogérance	Évaluer les risques (actions à distance, hébergement) et imposer : **réversibilité**, **audits**, sauvegarde en **format ouvert normalisé** et document contractuel du prestataire.

Connaître le système d'information

Notion	À retenir
Identification et cartographie	Identifier les **données sensibles** (activité, clients, usagers) → **composants critiques** (bases, postes, sauvegardes). Tenir à jour le **schéma réseau** (zones IP, adressage, routage, sécurité, interconnexions).
Inventaire des comptes	Inventorier **comptes à droits spécifiques** (administrateurs, accès répertoires, postes non administrés). Utiliser **nomenclature claire** (comptes de service vs administration) et effectuer **revue périodique**.
Effectifs et équipements	Révoquer **tous les droits** au départ ; seuls les **terminaux maîtrisés** sur le réseau ; personnels/visiteurs sur un **Wi-Fi à SSID dédié**.

Synthèse de l'authentification et du contrôle des accès

Notion	À retenir
Identification nominale	Comptes **nominatifs** : identifier action/compromission. Comptes **génériques** (admin, user) **marginaux** (limités). Comptes de service (apache, mysqld) autorisés.
Gestion des droits	Lister **ressources précieuses** (données, bases, boîtes aux lettres). Définir **population autorisée**, contrôler accès (utilisateurs authentifiés/ciblés) et effectuer **revue régulière** des droits.
Politique de mot de passe	Risques : mot de passe, messageries. Utiliser **coffre-fort numérique** ou **chiffrement**. **Blocage après échecs**, désactiver connexion anonyme, audit robustesse.
Équipements d'authentification	Modifier **configurations par défaut** à l'installation. Recommandation : **authentification forte à deux facteurs** (savoir + posséder/être). Signaler identifiant par défaut immuable au distributeur.

Sécurisation des postes

Notion	À retenir
Niveau minimal	Applications et modules navigateur limités, **pare-feu local**, **antivirus**, partitions chiffrées, **autorun** désactivé ; supports USB inconnus proscrits ; **gestion centralisée**.
Données par Internet	Chiffrer **systématiquement** avant envoi/hébergement. Transmettre le **secret de déchiffrement** via un **canal de confiance** ou **distinct** (main propre, téléphone).

Sécurisation du réseau

Notion	À retenir
Segmenter et cloisonner	Zones aux besoins homogènes (**VLAN**, **sous-réseaux IP** dédiés) ; filtrage IP par **pare-feu** entre zones et cloisonnement des tâches d'administration.
Sécuriser le Wi-Fi	Chiffrement **WPA2** avec **AES CCMP** ; authentification par **certificats clients** ; SSID et VLAN distincts pour terminaux personnels/visiteurs.
Protocoles sécurisés	Utiliser **TLS** (identifié par un **s** final : **HTTPS**, **IMAPS**, **SMTPS**, **POP3S**) et **SSH** (remplace **Telnet** et **Rlogin**).
Services Internet	Hébergement externalisé ou infrastructures physiquement cloisonnées ; **reverse proxy**.
Protéger la messagerie	Antivirus en amont, **TLS** ; pas de redirection vers une messagerie personnelle.
Interconnexion partenaires	Tunnel site à site (**IPsec**) via Internet ; filtrage IP par **pare-feu** au plus près de l'entrée ; matrice des flux réduite.
Accès physique	Contrôle par **serrures** ou **badges** ; traçabilité et limitation horaire des prestataires ; désactiver prises réseau en zones publiques.

Sécurisation de l'administration

Notion	À retenir
Accès Internet	Un poste ou serveur d'administration ne doit **jamais** avoir accès à **Internet**. Utiliser un **poste distinct** ou une **infrastructure bureautique virtualisée distante**.
Réseau dédié	Le réseau d'administration doit être **cloisonné** du réseau bureautique. Options : **cloisonnement physique**, **cloisonnement logique cryptographique** (`IPsec`) ou au minimum **VLAN**.
Droits utilisateurs	Par défaut, **aucun utilisateur** n'a de privilèges. Toute **délégation ponctuelle** est **tracée**, **limitée dans le temps** et **retirée à échéance**.

Gestion du nomadisme

Notion	À retenir
Terminaux et données	**Banalisés**, filtre de confidentialité, à portée de vue ; données **chiffrées** sur tout matériel perdable (chiffrement complet du disque d'abord).
Connexion et politique	**VPN IPsec** automatique et **non débrayable** ; pas de mutualisation personnel/professionnel ; gestion centralisée des mobiles (**MDM**).

Maintenance du SI

Notion	À retenir
Politique de mise à jour	S'informer via **CERT-FR**. Appliquer correctifs sous **un mois**. Utiliser `WSUS` ou tiers. Isoler composants obsolètes (filtrage réseau, secrets d'authentification).
Anticiper les fins de maintenance	**Inventaire** systèmes/applications. Support = durée utilisation. **Clauses contractuelles** (correctifs/obsolescence). Ressources migration (tests, sauvegarde, données).

Synthèse de la supervision et de la réaction

Notion	À retenir
Journalisation	Journaliser paquets bloqués, authentifications, arrêts inopinés, erreurs **HTTP 403, 404, 500** ; garder événements critiques **au moins un an**.
Sauvegarde	Politique formalisée incluant mode **hors ligne**, fréquence, stockage et **tests de restauration** (systématiques, ponctuels ou généraux).
Audits et référent	Audit **au moins annuel** suivi par un **tableau de bord** ; **référent** sécurité (relais du **RSSI**).
Gestion incidents	En cas d'intrusion : **déconnecter du réseau**, maintenir **sous tension** (ne pas redémarrer), prévenir hiérarchie et référent.

Pièges et confusions

- ⚠ Confondre l'audit de sécurité avec la preuve de l'absence de vulnérabilité
- ⚠ Croire qu'un poste d'administration peut avoir accès à Internet
- ⚠ Utiliser un compte générique au lieu d'un compte nominatif pour identifier une action
- ⚠ Oublier de maintenir un équipement sous tension lors d'une intrusion

Sigles et définitions

Authentification forte	Authentification exigeant deux facteurs différents parmi ce que je sais, ce que je possède et ce que je suis
Compte nominatif	Compte d'accès rattaché à une personne physique identifiée
Réversibilité du contrat	Exigence de restituer les données dans un format ouvert normalisé et de permettre le retour à une exploitation interne
Segmentation du réseau	Découpage en zones regroupant des systèmes aux besoins de sécurité homogènes
MDM	Solution de gestion centralisée des équipements mobiles

Auto-test

1. Quels sont les trois types de facteurs d'authentification ?
2. Que signifie le principe du moindre privilège ?
3. Quel outil est utilisé pour le déploiement des mises à jour Microsoft ?
4. Quelle est la durée minimale de conservation des journaux des composants critiques ?
5. Que faut-il faire d'un équipement en cas d'intrusion ?

Réponses : **1.** Connaissance, possession et inhérence · **2.** Un utilisateur ne dispose que des droits strictement nécessaires · **3.** WSUS · **4.** Au moins un an · **5.** Déconnecter du réseau et maintenir sous tension

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.